

数字赋能系统免密跳转

第三方系统内页流程

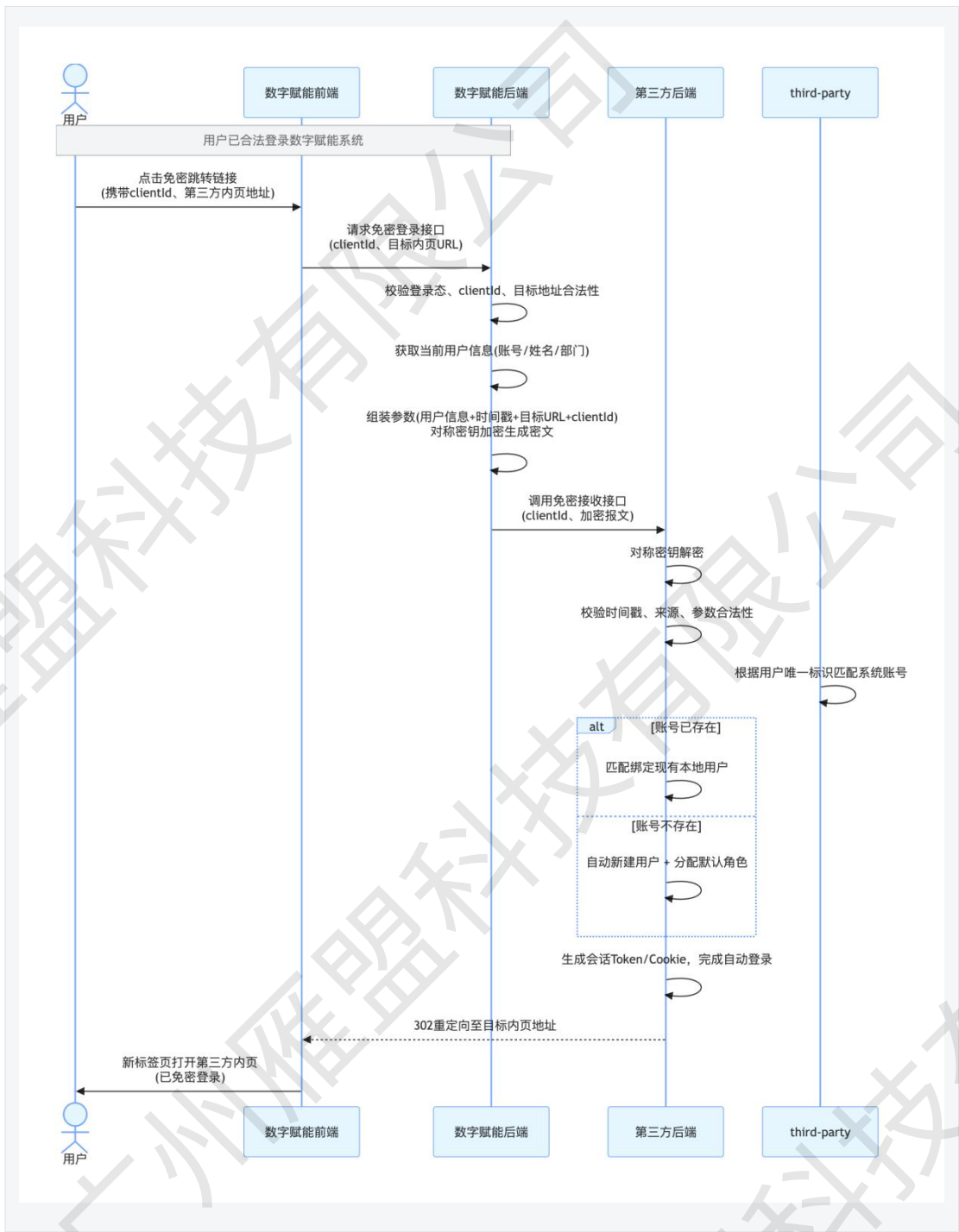
一、流程核心前提

- 用户已完成数字赋能系统登录，持有合法登录态（如 Token）；
- 双方提前约定：对称加密密钥、clientId（第三方系统在数字赋能系统的唯一标识）、参数加密规则、第三方系统响应接口地址；
- 第三方系统已开发免密接收接口，支持用户信息匹配、自动新建用户及默认角色分配；
- 跳转目标为第三方系统指定内页（需提前明确内页地址，由数字赋能系统携带参数传入）。

二、完善后交互流程

核心逻辑：数字赋能系统携带合法参数+加密用户信息请求第三方免密接口，第三方解密校验后完成用户匹配/新建、自动登录，最终重定向至目标内页，全程无需用户额外操作。

序列图



三、流程细节补充

1. 参数加密与校验细节

对称加密需约定密钥更新机制（定期更换，提升安全性）；时间戳建议设置短期有效期（如 5 分钟），避免加密串被恶意复用；加密参数需增加“签名”字段（可选，基于加密串+密钥生成），第三方后端额外校验签名，防止加密串被篡改。

2. 用户匹配与新建规则

双方提前约定“用户匹配唯一字段”（优先选择数字赋能与第三方系统可能一致的字段，如工号、统一账号）；自动新建用户时，默认角色需提前确认（如“普通用户”），权限范围限定为第三方系统基础访问权限，避免越权；新建用户后，可同步记录“来源=数字赋能免密登录”，便于后续追溯。

3. 异常处理补充

- 若第三方系统用户状态异常（如冻结、注销），即使匹配成功，也需拦截免密登录，返回异常提示并引导手动登录；
- 数字赋能后端若无法获取用户信息（如登录态过期），立即拦截请求，提示用户重新登录数字赋能系统；
- 第三方系统内页地址若未在白名单内，直接返回非法地址提示，拒绝跳转。

4. 前端交互优化

数字赋能前端点击链接后，可添加“跳转中...”加载提示，提升用户体验；第三方系统重定向过程中，若出现延迟，可显示过渡页面，避免用户误以为跳转失败。

附：第三方系统响应接口设计参考

以下设计仅供参考，若第三方系统已有自己的接口设计，可提供文档供数字赋能对接。

一、接口基础信息

项目	详细内容
接口名称	数字赋能系统免密登录接收接口
接口用途	接收数字赋能系统传递的加密用户信息及跳转参数，完成免密登录及内页重定向
接口地址 (模拟)	https://third-party-system.com/api/sso/jump
请求方式	POST（推荐，保障参数传输安全，避免明文暴露）
数据格式	推荐：application/json（JSON 格式提交）
响应方式	1. 校验通过：HTTP 302 重定向至目标内页（已完成自动登录） 2. 校验失败：返回 JSON 格式错误信息
接口超时 时间	默认 3000ms，双方可根据实际情况协商调整
安全约定	1. 采用双方约定的对称密钥进行参数加密/解密； 2. 时间戳有效期限限制（默认 5 分钟），防止请求重放； 3. clientId 白名单校验，仅允许指定来源系统调用。

二、请求参数说明

请求参数由数字赋能后端传递至第三方系统后端，所有必填参数不可缺失，否则接口直接返回失败。

参数名	数据类型	是否必填	参数说明	示例值
clientId	String	是	数字赋能系统的唯一标识，由双方提前约定并录入第三方系统白名单，用于校验请求来源合法性	empower_001
encryptData	String	是	核心加密参数，使用双方约定的对称密钥加密，解密后包含用户信息、时间戳、目标内页地址等核心业务数据（具体解密后结构见下方）	a1b2c3d4e5f6 7890abcdef12 34567890 (示例密文)
timestamp	Long	是	请求时间戳，单位为毫秒，用于校验请求是否过期（默认 5 分钟内有效）	17400000000 00
sign	String	否（推荐）	签名参数，增强接口安全性，生成规则： MD5(clientId + encryptData + timestamp + 对称密钥)，第三方系统校验签名一致性，防止参数被篡改	888888888888 888888888888 888888888888

2.1 encryptData 解密后原文结构（JSON 格式）

加密原文包含用户核心信息及跳转相关参数，字段不可缺失，第三方系统解密后需逐一校验字段合法性。

```
json
{
  "userName": "13500000000",    // 必选，数字赋能系统用户账号，可作为第三方系统用户匹配的唯一依据
  "nickName": "张三",          // 必选，用户姓名，用于新建用户时录入第三方系统
  "phoneNumber": "13500000000", // 可选，用户手机号码
  "targetUrl": "/dashboard/home", // 必选，目标内页地址，第三方系统校验通过后重定向至此地址
  "clientId": "empower_001",    // 必选，与请求参数中的 clientId 一致，双重校验
  "timestamp": 1740000000000    // 必选，与请求参数中的 timestamp 一致，双重校验
}
```

三、响应规则说明

3.1 响应成功（免密登录+重定向）

项目	详细内容
HTTP 响应码	302 Found
响应头	Location: https://third-party-system.com{targetUrl}（即解密后获取的目标内页地址，拼接第三方系统域名）
响应体	无（浏览器自动识别 302 状态码，跳转到 Location 指定的地址）
业务说明	第三方系统已完成用户匹配/新建、自动登录，生成本地登录会话（Cookie/Token），跳转后用户可直接访问目标内页（已处于登录状态）

3.2 响应失败（校验异常）

当接口校验失败（如解密失败、clientId 无效等），返回 JSON 格式错误信息，便于双方

排查问题。

项目	详细内容
HTTP 响应码	400（参数错误） / 500（服务器异常）
响应体格式	JSON 格式，包含 code（错误码）、msg（错误说明）、success（是否成功）三个字段
响应示例	<pre>{ "code": 40001, "msg": "密文解密失败，请检查加密密钥是否一致", "success": false }</pre>

四、接口处理流程（第三方系统后端）

- 接收数字赋能后端传递的请求参数（clientId、encryptData、timestamp、sign（可选））；
- 基础校验：校验必填参数是否齐全，若缺失，返回 code=40000，msg=“必填参数缺失”；
- clientId 校验：校验请求中的 clientId 是否在第三方系统的白名单内，若无效，返回 code=40002，msg=“clientId 无效，请求来源不合法”；
- 签名校验（可选）：若传递了 sign 参数，按照约定规则重新计算签名，与请求中的 sign 比对，不一致则返回 code=40006，msg=“签名校验失败，参数可能被篡改”；
- 时间戳校验：计算当前时间与请求 timestamp 的差值，若超过约定有效期（默认 5 分钟），返回 code=40003，msg=“请求已过期，请重新发起”；
- 密文解密：使用双方约定的对称密钥对 encryptData 进行解密，解密失败则返回 code=40001，msg=“密文解密失败，请检查加密密钥是否一致”；
- 解密后参数校验：校验解密后的 userAccount、targetUrl 等核心字段是否存在，targetUrl 是否为第三方系统允许访问的内页地址（白名单校验），若不合法，返回

code=40004, msg=“目标地址不合法”;

- 用户匹配与新建：根据解密后的 userAccount，查询第三方系统本地用户：
- 若匹配到已有用户：校验用户状态是否正常（未冻结、未注销），状态异常则返回 code=40007, msg=“用户状态异常，无法完成登录”；状态正常则直接关联该用户；
- 若未匹配到用户：自动新建用户，录入 userName、userAccount、dept 等信息，并为用户分配预设的默认角色（如“普通用户”，权限范围提前约定），新建失败则返回 code=40005, msg=“用户创建失败，请联系管理员”；
- 自动登录：为关联/新建的用户生成本地登录会话（Cookie 或 Token），标记登录方式为“免密登录”，会话有效期与第三方系统常规登录一致；
- 重定向：返回 302 状态码，Location 设置为解密后的 targetUrl（拼接第三方系统域名），引导浏览器跳转到目标内页，完成免密登录流程。

五、错误码定义（统一规范）

错误码按业务场景分类，便于双方快速定位问题，所有错误响应均遵循“code+msg+success”的 JSON 格式。

错误码 (code)	错误说明 (msg)	业务场景	排查建议
200	成功	接口处理正常（本接口成功直接 302 重定向，不返回此 code)	无需排查
40000	必填参数缺失	请求参数中 clientId、encryptData、timestamp 有缺失	检查数字赋能后端请求参数是否齐全
40001	密文解密失败	encryptData 解密异常	检查双方对称密钥是否一致，加密/解密算法是否统一

40002	clientId 无效，请求来源不合法	请求的 clientId 未在第三方系统白名单内	确认双方约定的 clientId，检查第三方系统白名单配置
40003	请求已过期	timestamp 超出约定有效期	检查数字赋能后端时间戳生成逻辑，确保请求在有效期内发起
40004	目标地址不合法	解密后的 targetUrl 不在第三方系统内页白名单	确认目标内页地址是否正确，检查第三方系统内页白名单配置
40005	用户创建失败	未匹配到用户，自动新建用户时异常	检查第三方系统用户创建接口，确认默认角色配置是否正常
40006	签名校验失败，参数可能被篡改	sign 参数与计算结果不一致	检查双方签名生成规则、密钥是否一致，参数是否被修改
40007	用户状态异常，无法完成登录	匹配到的用户处于冻结、注销状态	检查第三方系统用户状态，解锁或重新激活用户
50000	服务器异常，请稍后重试	第三方系统后端处理过程中出现异常（如数据库异常）	检查第三方系统服务器日志，排查后端处理逻辑

六、对接注意事项

- 双方需提前确认对称密钥，密钥需定期更换（建议每月更换一次），避免密钥泄露导致安全风险；

- encryptData 加密时，需确保原文字段完整，避免缺失 userAccount、targetUrl 等核心字段；
- 目标内页地址（targetUrl）需提前在第三方系统登记白名单，未登记的地址将被拦截；
- 接口调用过程中，数字赋能后端需确保请求参数的准确性，尤其是 timestamp 的时效性；
- 第三方系统自动新建用户时，默认角色的权限需提前与数字赋能系统约定，避免权限过高或过低；
- 双方需做好接口日志记录，便于登录失败、跳转异常等问题的排查；
- 若需调整接口参数、加密规则或响应逻辑，双方需提前沟通确认，同步更新对接文档。